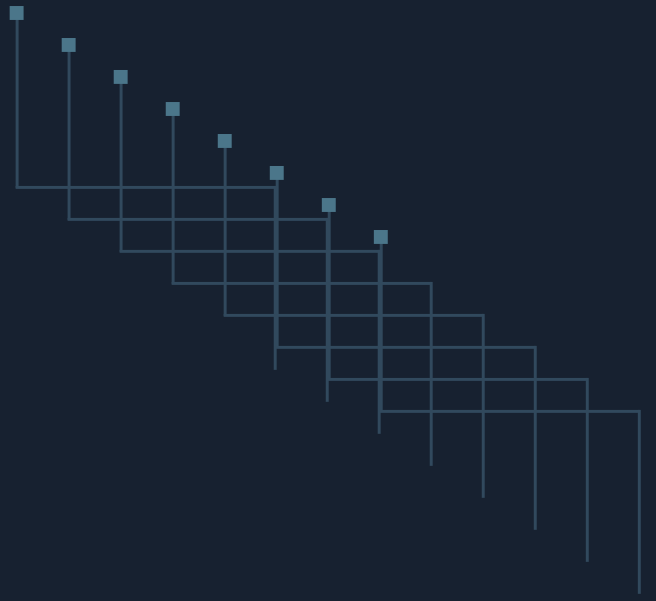
EngineSquare

PROJECT REPORT

통합 보안 관제 시스템 구축 프로젝트

결과 보고



ALEPH 3 조 / EngineSquare
강아름 (시나리오 1) · 김라연 (시나리오 2) · 유지원 팀장 (시나리오 3)

CONTENTS

발표 순서

01 프로젝트 개요 · 아키텍처

02 시나리오 1 로그 버퍼링 Middleware (강아름)

03 시나리오 2 유출 API 키 탐지 · 자동 대응 (김라연)

04 시나리오 3 킬체인 상관분석 · IoT 대응 (유지원)

05 통합 결론 · 향후 계획

06 Q&A

세 시나리오 , 세 명의 담당

1

강아름

시나리오 1 · Middleware

- 대량 로그 수집 · 버퍼링
- SQLite WAL 브로커
- 2 만 건 무손실 검증

2

김라연

시나리오 2 · 인증 · 인가

- 유출 API 키 탐지 · 대응
- 공용 웹앱 · API · MySQL
- Wazuh 규칙 100310~100312

3

유지원 (팀장)

시나리오 3 · 킬체인 ·IoT

- Graylog 상관분석 규칙
- n8n 자동 대응 · pfSense
- ESP32-C3 LED· 부저 장비

흩어진 로그를 하나의 대응 흐름으로

추진 배경

- 포트스캔 · 무차별 대입 · 유출 키 · 비정상 장비 제어
- 시스템별 로그가 분산돼 공격 흐름 파악이 어려움
- 대량 로그 집중 시 지연 · 유실로 탐지 정보 누락

프로젝트 목적

- Middleware 로 보안 로그를 안정적으로 수집 · 전달
- Graylog·Wazuh 로 이상 사용과 공격 흐름 분석
- n8n 으로 키 교체 ·IP 차단 ·IoT 보호 자동 대응

공격 재현
Kali · Postman

→

로그 수집
Middleware

→

분석 · 탐지
Graylog · Wazuh

→

자동 대응
n8n

→

인시던트 확인
공용 대시보드

3 대 위협 시나리오와 대응 방향

시나리오	위협 상황	대응 방향
1 · Middleware	스캔 · 무차별 대입으로 로그가 몰려 지연 · 전송 실패	수집 · 버퍼링 · 속도 제어 · 재시도로 전달 안정성 확보
2 · 유출 API 키	정상 발급 키가 비허용 IP 에서 재사용	키 · 출발지 IP 검증 , 키 교체와 공격 IP 차단
3 · 킬체인 ·IoT	같은 공격자의 정찰 · 키 재사용 · 장치 제어 연속 발생	단계별 상관분석 , CRITICAL 시 차단과 장비 대응

시나리오 1 이 로그를 안정적으로 모으고 , 시나리오 2 가 개별 이벤트를 막고 , 시나리오 3 이 그 연결을 본다 .

전체 아키텍처 : 탐지는 Graylog, 대응은 n8n

API 서버 · IoT
로그 발생

→

Middleware
시나리오 1

→

Graylog
시나리오 2·3 규칙

→

n8n
웹훅 · 분기

▼ n8n 이 병렬로 호출하는 대응

키 폐기 · 교체
시나리오 2

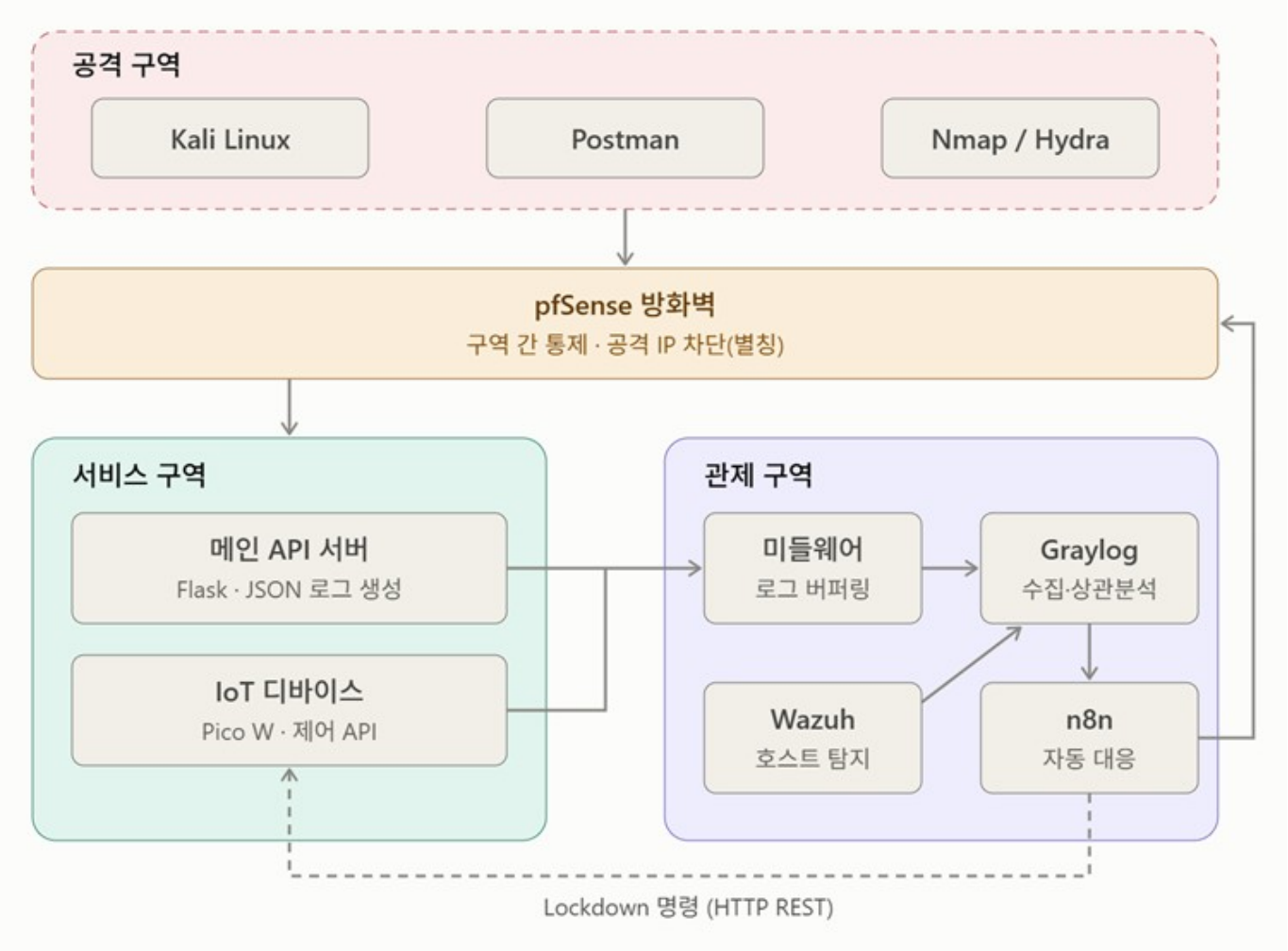
pfSense IP 차단
시나리오 3

ESP32 LED · 부저
시나리오 3

공용 대시보드
MySQL · INC 티켓

Wazuh 원본 JSON 로그를 별도 경로로 수집해 사용자 정의 규칙 100310~100312 를 검증한다 (n8n 직접 호출 없음)

네트워크 토폴로지 : 구역을 나누고 방화벽이 통제한다



공격 구역

Kali Linux, Postman, Nmap/Hydra 로 공격 재현

pfSense 방화벽

구역 간 통제 , n8n 이 호출하면 공격 IP 차단

서비스 구역

메인 API 서버와 IoT 디바이스 , 로그 생성

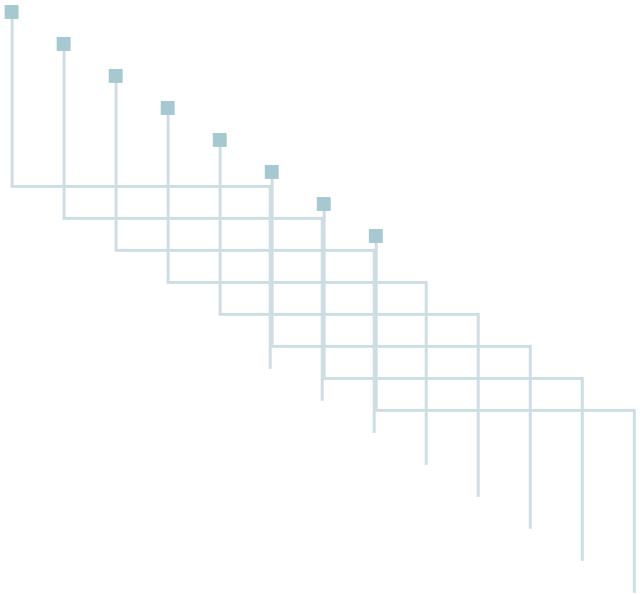
관제 구역

미들웨어 → Graylog 상관분석 → n8n 자동 대응 , Wazuh 호스트 탐지

01

로그 버퍼링 Middleware

대량 공격 트래픽에도 로그를 잃지 않는 수집 파이프라인



대량 트래픽 발생시 , 영구 유실되는 로그들

37.6%

3 초 장애 · 500 건 중 188 건 영구 유실

8.2%

15 초 장애 · 20,000 건 중 1,644 건 영구 유실

연쇄 장애

관제 인프라 병목이 웹 서버 스레드 고갈로 번져 정상 서비스 마비

숨은 위험

- 장애 격리 실패

  로그를 직접 보내면 관제 시스템의 응답 지연이 웹 서버의 커넥션과 메모리를 잠식합니다 . 관제 시스템 하나 때문에 전체 서비스가 다운되는 치명적인 연쇄 장애로 이어집니다 .

수집기 → 브로커 → 컨슈머 , 역할 분리

비동기 수집기
인증 · 마스킹 · 202 즉시 반환



SQLite WAL 브로커
디스크 영속 · IP 해시 파티션



컨슈머 워커
초당 500 건 · 선별 재시도



Graylog
상관분석 입력

서비스 보호

- 큐 초과 시 503 백프레셔
- 서킷 브레이커로 관제 장애 격리

우선순위 처리

- 허니토큰 · 위급 로그는 우선 토픽
- 70 : 30 가중 드레인

킬체인 순서 보장

- IP 의 CRC32 로 파티션 고정
- 원본 발생 시각 보존

핵심 설정값

1,000 건 / 초

인증 키당 수집 속도

10 만 건

인메모리 버퍼 큐

500 건 / 초

Graylog 방출 상한

70 : 30

우선순위 : 표준 드레인

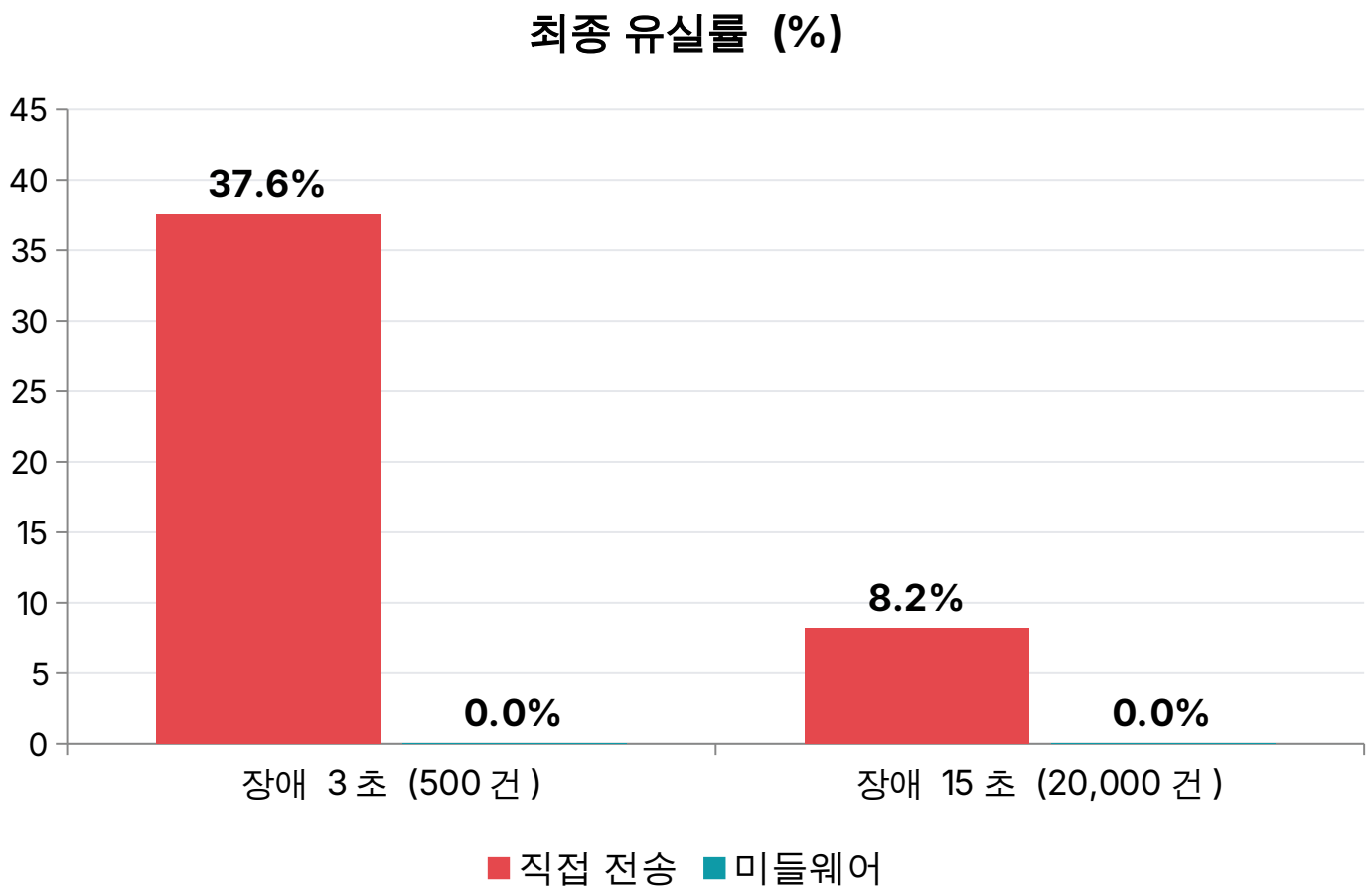
최대 8 회

지수 백오프 1~30 초

3 회 실패

서킷 브레이커 OPEN

Graylog 가 멈춰도 0 건 유실



20,000 건

전량 수락 · 평균 12.24ms (P99 68.2ms)

+52 건

15 초 장애 중 재전송 중복 (+0.3%)

고유 데이터 20,000 건은 전량 보존 . 전송 보장 수준은 At-Least-Once.

시연 : 직접 전송과 미들웨어 적용 비교

1 환경 확인 · 기준 건수 0

2 Graylog pause (장애 주입)

3 직접 전송 500 건 → 유실 확인

4 미들웨어 경유 500 건 → 0 건 유실



5 단계 무손실 감사 결과 : PASS (유실 0)

[RESILIENCE UNDER SIEM DISTRESS: COMPREHENSIVE DUAL-SCENARIO REPORT]

Metric	[Scenario A] 500 logs / 3s Pause		[Scenario B] 20k logs / 15s Pause	
	Direct Graylog	SOAR Middleware	Direct Graylog	SOAR Middleware
Target Endpoint	POST /gelf	POST /v1/ingest	POST /gelf	POST /v1/ingest
Client Concurrency	20 workers	20 workers	50 workers	50 workers
Client Timeout	3.0s	3.0s	3.0s	3.0s
Client Retry Policy	1 Retry (0.5s)	0 (WAL Decoupled)	1 Retry (0.5s)	0 (WAL Decoupled)
Downstream Distress	Pause (3.0s)	Pause (3.0s)	Pause (15.0s)	Pause (15.0s)
Client Ingest Duration	3.89s	2.51s (WAL)	117.66s	117.67s (WAL)
Client Ingest Throughput	128 req/s	199 logs/s	170 req/s	170 logs/s
Service Latency (Pure RTT Avg)	234.75 ms	9.89 ms	60.42 ms	12.01 ms
- Service P95 / P99	3003.6 / 3032.1 ms	19.4 / 27.5 ms	340.8 / 1049.2 ms	27.2 / 60.9 ms
Total Latency (Queue+Wait Avg)	2162.90 ms	9.86 ms	461.33 ms	12.24 ms
- Total P95 / P99	3000.0 / 3022.6 ms	30.5 / 39.8 ms	3000.0 / 3014.2 ms	36.8 / 68.2 ms
Client Logs Accepted	295	500	17,757	20,000
Client Logs Failed (Loss)	205	0	2,243	0
End-to-End Delivered (DB)	312 logs (312 uniq)	500 logs (500 uniq)	18,356 logs (18,356 uniq)	20,052 logs (20,000 u
End-to-End Log Loss Rate	37.6% (188 lost)	0.0% (0 lost)	8.2% (1,644 lost)	0.0% (0 lost)
End-to-End Duplicate Rate	0.0% (Clean)	0.0% (Clean)	0.0% (Clean)	+0.3% (+52 dups)
Architectural Verdict	UNPROTECTED (188 lost)	0 LOST, 0 DUPS (Observed)	UNPROTECTED (1,644 lost)	ZERO-LOSS (At-

* Note 1: 인제스터 단일 워커 최적 동시성(concurrency=50) 기준이며, 대규모 확장은 Kafka 전환 로드맵을 참조합니다.
* Note 2: At-Least-Once 파이프라인으로 10초 초과 장기 다운타임 시 정상 재전송에 따른 중복이 발생할 수 있습니다.
* Note 3: OpenSearch 적재 건수는 DB 실제 카디널리티 쿼리로 실측 검증했습니다(실패 시 UNVERIFIED 처리 후 sys.exit(2)).

문제와 해결 : 만든 만큼 측정해서 찾았다

문제	원인	해결
배치 100 건 중 99 건 소실	Graylog 6.1 이 NDJSON 첫 건만 파싱	20 스레드 단건 병렬 전송 , 전수 실측
장애 대기 중 기록 영구 유실 위험	대기 중에도 기록을 꺼내서 버리면 , 복구 후 " 처리 완료 " 로 표시됨	조회를 메모리 캐시로 대체 (1 초 주기 갱신) IPv4 고정 , 쿨다운 3 초
측정값이 실제값과 다름	응답 수 × 묶음 크기로 성공을 계산	OpenSearch 저장 문서를 조회하여 집계

결과 : 2 만 건 연속 인입 시 전송오류 0 건

개선 방향 : 규모에 맞는 단계 확장

현재

SQLite WAL

서버 1대 · 메모리 384MB 로 바로 도입

중규모

Redis Streams

초당 1만 건 · 파일 락 병목 해소

대규모

Kafka / Redpanda

초당 10만 건 + · 수평 확장

멱등성 보강

- 교체 시 업무 코드 수정 없음 (Kafka 규격 인터페이스)
- 중복 기록은 _event_id 매핑으로 OpenSearch 단계에서 제거

02

유출 API 키 탐지 · 자동 대응

키와 출발지 IP 를 함께 검증하고, 이상 사용은 사람 손 없이 막는다

유효한 키여도 출발지 IP 가 다르면 거부

200

허용 IP + 활성 키

authorized

403

비허용 IP + 활성 키

Client IP is not allowed

401

허용 IP + 폐기된 키

API key is revoked

보호 대상과 목표

- EngineSquare 공용 API 와 데이터
- 공격자가 유효한 키를 가져도 허용 IP 밖에서는 접근 거부 , 탐지 이후 추가 사용 제한

탐지부터 키 교체 ·IP 차단까지 자동

1 비허용 IP 요청 → 2 403 거부 로그 생성 → 3 Graylog 탐지 → 4 n8n 대응 호출 → 5 키 폐기 · 재발급 IP 차단 → 6 INC-API 티켓

검증용 키는 해시 저장

- DB 에는 키 해시 저장
- 로그에는 키 식별자만 기록

재시작 없이 반영

- MySQL 로 키 · 차단 상태 조회
- 다음 요청부터 변경 반영

교체 키 전달

- 교체 키 원본은 암호화해 임시 보관
- 관리자 확인 후 암호문 삭제

공용 웹앱 ·API 서버 ·DB 통합 구현

담당 범위 | 공용 웹앱 · API 서버 · DB 연동

공용 웹앱
대시보드 · 티켓 · 관리자

↔

공유 MySQL
키 · 차단 · 사고 상태

↔

Flask API 서버
요청 검증 · 자동 대응

탐지 · 대응 연동 | 보호 API 의 보안 로그 전달

Middleware
로그 수집 · 전달

→

Graylog
이상 사용 탐지

→

n8n
대응 API 호출

→

대응 API
키 교체 ·IP 차단

대응 API 는 Flask 서버에 구현 · 변경된 상태는 공유 DB 를 통해 반영

공용 웹앱에서 사고와 대응 결과 확인

① 사고 티켓 | 시나리오별 대응 조치 · 반복 횟수 확인

인시던트 티켓 30건 모두 종료

탐지된 보안 이벤트와 처리 상태를 확인합니다.

전체 | 열림 | 종료 | 이전 | 1 / 6페이지 | 다음

#	출발지 IP	심각도	상태	관련 이벤트	횟수	조치	제목	생성 시각	종료 시각
INC-API-021	10.10.10.11	높음	열림	api_key_compromised	2회	키 폐기·IP 차단	**API 키 이상 요청 탐지**	2026-11-05 16:03:59	종료
INC-KILLCHAIN-011	10.0.0.210	높음	열림	killchain_critical	2회	pfSense 차단 + IoT Lockdown 외부 대응 보고	**킬체인 상관분석 CRITICAL**	2026-11-04 18:13:02	종료

② 최근 이벤트 | 정상 · 거부 요청과 탐지 결과 확인

최근 이벤트 48건

최근 수집된 보안 이벤트를 확인합니다.

전체 | 거부 | 허용 | 이전 | 1 / 10페이지 | 다음

#	시나리오	출발지 IP	판정	심각도	사유	저장 시각
48	시나리오 2 · API 키 유출 탐지	10.10.10.11	⊘ 거부	높음	이미 차단된 IP의 요청 · API 키 폐기/없음	2026-11-05 16:06:16
47	시나리오 2 · API 키 유출 탐지	10.10.10.11	⊘ 거부	높음	이미 차단된 IP의 요청 · API 키 활성	2026-11-05 16:03:59
46	정상 API 요청	127.0.0.1	✓ 허용	낮음	정상 API 키 인증	2026-11-05 16:03:39

시연 : 정상 → 유출 → 자동 대응 → 이용 재개

단계	요청 · 확인	결과
정상 접근	허용 IP 에서 활성 키 사용	200 / authorized
비허용 IP	Kali 에서 동일 키 사용	403 / IP 접근 거부
로그 탐지	Middleware · Graylog 이벤트 확인	IP · 키 식별자 · 시각
자동 대응	n8n 실행 , 관리자 화면 확인	키 폐기 · 교체 · IP 차단
폐기 키 재사용	허용 IP 에서 기존 키 사용	401 / API key is revoked
이용 재개	허용 IP 에서 교체 키 사용	200 / authorized

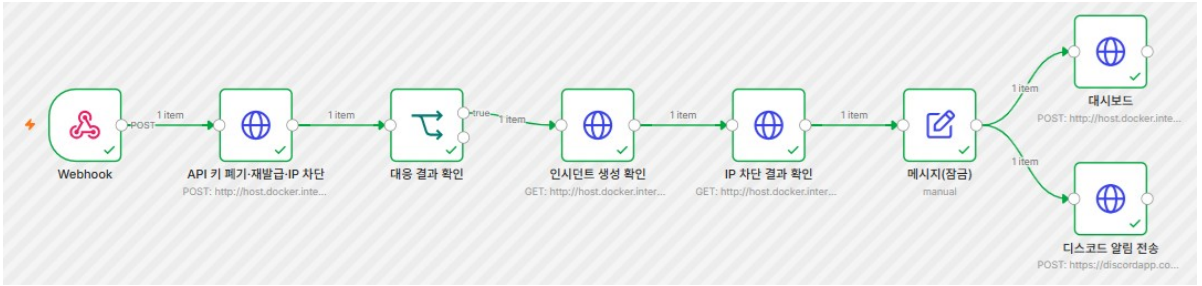
증적 : 403 응답 , n8n 실행 , 관리자 화면

① Kali · 비허용 IP 접근 거부

```
┌──(root㉿DESKTOP-VNKKAJJ)-[/mnt/c/Users/user]
└─# curl -i --connect-timeout 5 "http://$GW:5000/api/data" -H "X-API-Key: $API_KEY"
HTTP/1.1 403 FORBIDDEN
Server: Werkzeug/3.0.1 Python/3.13.15
Date: Thu, 29 Oct 2026 02:46:07 GMT
Content-Type: application/json
Content-Length: 66
Connection: close

{"error":"request_rejected","message":"Client IP is not allowed"}
```

② n8n · 자동 대응 실행 성공



③ 관리자 · 기존 키 폐기 / 교체 키 활성 / 공격 IP 차단

이름	식별자	상태	허용 IP	발급 시각	폐기 시각	관리
[교체] test-key	key-a872495528064adcb8ad7...	활성	127.0.0.1	2026-10-29 11:46:22	-	새 키 확인 폐기
test-key	key-f44710a6257849c9b06f23...	폐기	127.0.0.1	2026-10-29 11:43:41	2026-10-29 11:46:22	—

IP 주소	차단 사유	차단 시각	인시던트	관리
172.23.124.6	not_allowed_ip	2026-10-29 11:46:22	INC-API-005	차단 해제

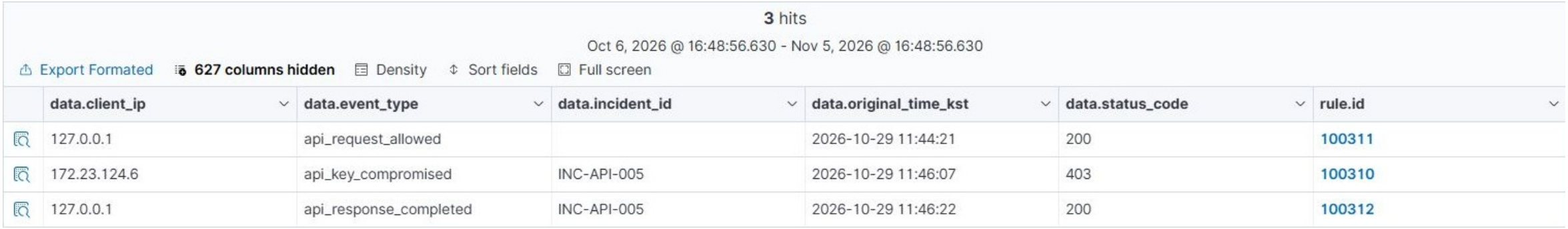
Wazuh 로 실시간 탐지도 별도 검증

규칙 ID	확인 대상	레벨
100310	비허용 IP 의 API 키 사용 · HTTP 403	10
100311	정상 API 요청 허용 · HTTP 200	3
100312	자동 대응 완료 · HTTP 200	3

INC-API-005

정상 요청 200 → 이상 접근 403 → 자동 대응 완료 200

규칙 100311·100310·100312 매칭 확인



3 hits

Oct 6, 2026 @ 16:48:56.630 - Nov 5, 2026 @ 16:48:56.630

Export Formated | 627 columns hidden | Density | Sort fields | Full screen

data.client_ip	data.event_type	data.incident_id	data.original_time_kst	data.status_code	rule.id
127.0.0.1	api_request_allowed		2026-10-29 11:44:21	200	100311
172.23.124.6	api_key_compromised	INC-API-005	2026-10-29 11:46:07	403	100310
127.0.0.1	api_response_completed	INC-API-005	2026-10-29 11:46:22	200	100312

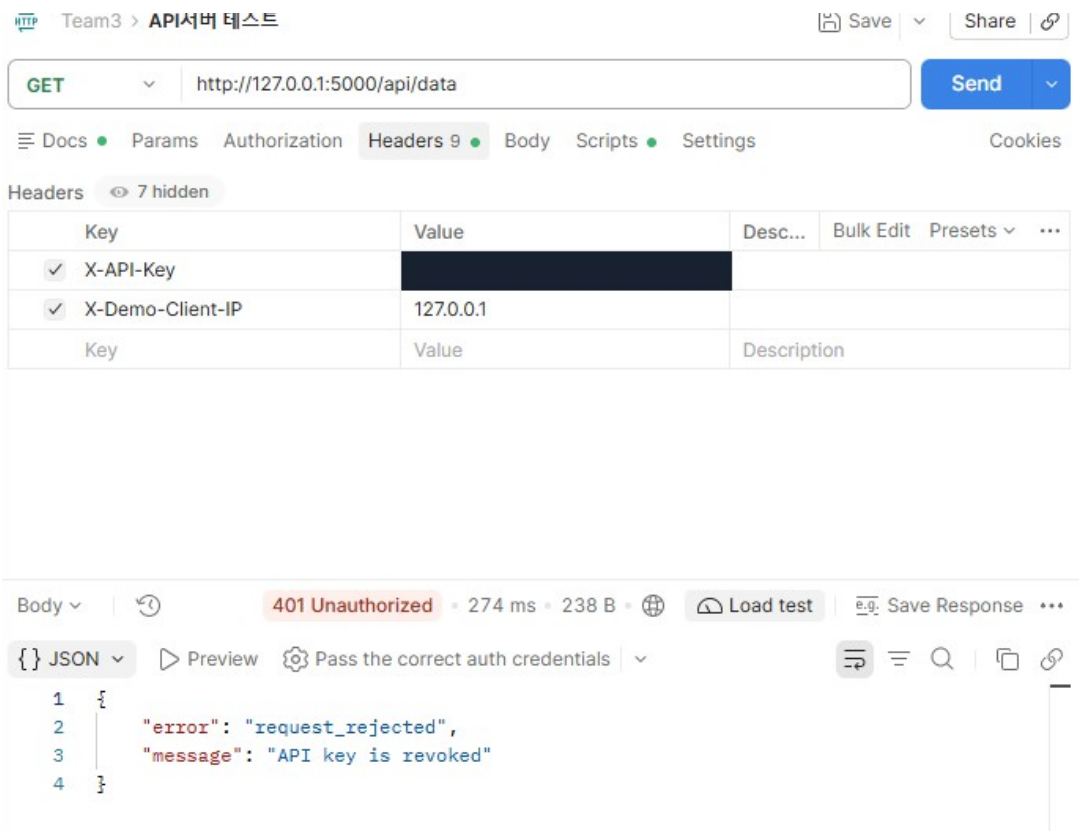
문제와 해결 : 연결 지점이 문제였다

문제	원인	해결
키 · 차단 상태 불일치	웹앱 ·API 의 DB 분리	서로 다른 SQLite → 공유 MySQL 로 통합 다음 요청부터 변경 반영
n8n 에 키 ·IP 누락	원본 로그와 알림 JSON 의 필드 전달 구조 불일치	알림 필드 · 참조 경로 수정 키 식별자와 공격 IP 전달
Wazuh 이벤트 미수집	로그 전달 수집기 실행 및 수집 대상 파일 설정 누락	수집기 실행 · 파일 설정 보완 규칙 3 종 매칭 확인

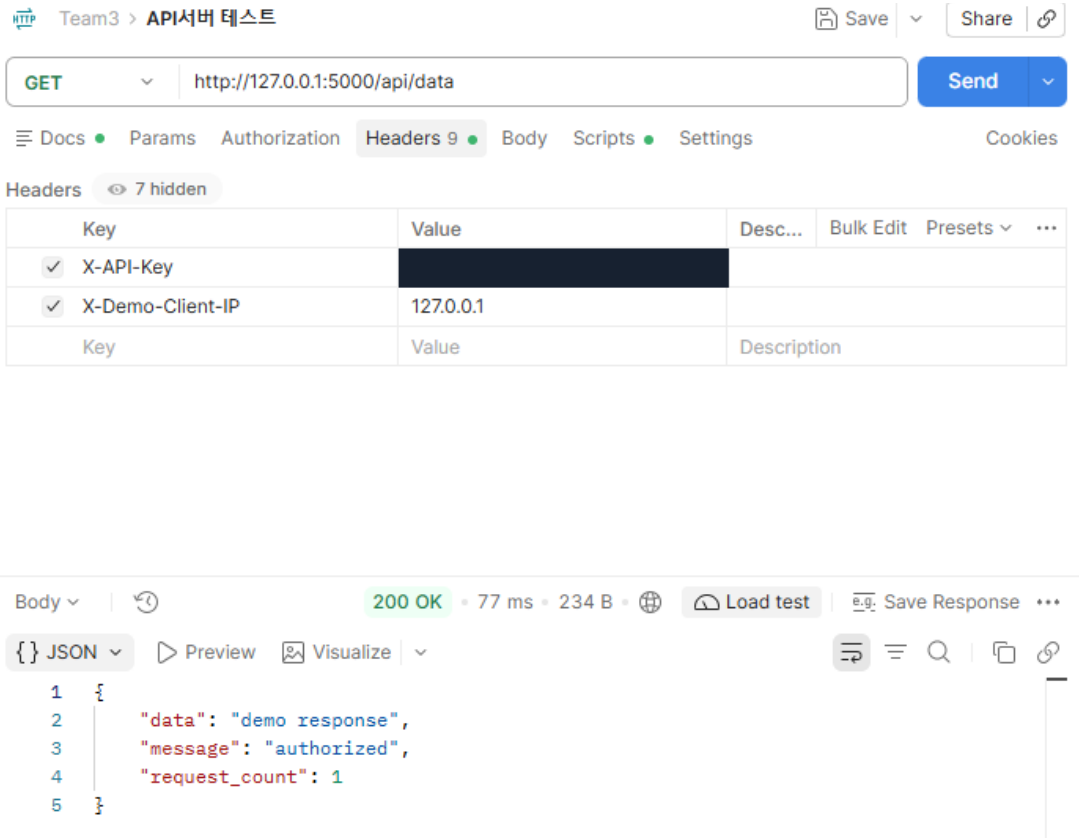
허용 IP 에서 기존 키 401 · 교체 키 200 으로 실제 동작 검증

기존 키 사용 중단과 정상 이용 재개 검증

기존 키 | 401 Unauthorized



교체 키 | 200 OK



동일한 허용 IP 에서 기존 키 거부 · 교체 키 정상 접근 확인

현재 한계와 개선 방향

01 허용 IP 내부의 악용까지 탐지

현재 한계 : 유효한 키 · 허용 IP 만으로는 내부 악용 판단에 한계

개선 방향 : 요청량 · 접근 자원 · 반복 오류를 함께 분석

02 Wazuh 탐지를 자동 대응으로 확장

현재 한계 : Wazuh 는 별도 검증 , 자동 대응은 Graylog→n8n 에서 실행

개선 방향 : Wazuh·n8n 연동과 동일 사고의 중복 대응 방지

SCENARIO 03 / 유지원 (팀장)

03

킬체인 상관분석 · IoT 대응

정찰 → 침투 → 장치 제어가 이어지면 자동 차단하고 LED 로 알린다

벽시계처럼 , 보안 상태를 한눈에 보는 장치

SECURITY STATUS



벽에 걸린 관제 LED 패널 (상상도)

파랑 부팅
초록 정상
노랑 경고
빨강 위급

1

보안 회사엔 공격이 계속 들어온다

대시보드와 알림 메시지는 충분히 많다 .
그래도 가장 직관적인 건 벽시계처럼 한눈에 보이는 것 .

2

공격은 온라인에만 오지 않는다

출입문 같은 물리 장치에도 API 공격이 가능하다 .
감지 즉시 물리적으로 표현하는 IoT 가 필요 .

3

그래서 LED 로 위험도를 말한다

상관분석이 위험을 판정하면 사람 손 없이 , 장비가 색으로 알리고
차단까지 이어진다 .

시연 순서 : 환경 점검 → 경고 → 위급 → 해제



환경 점검

컨테이너 6 개 · 보드 초록



2 단계만 전송

정찰 + 침투
→ 노랑 WARNING



3 단계 전송

장치 제어까지
→ 빨강 CRITICAL

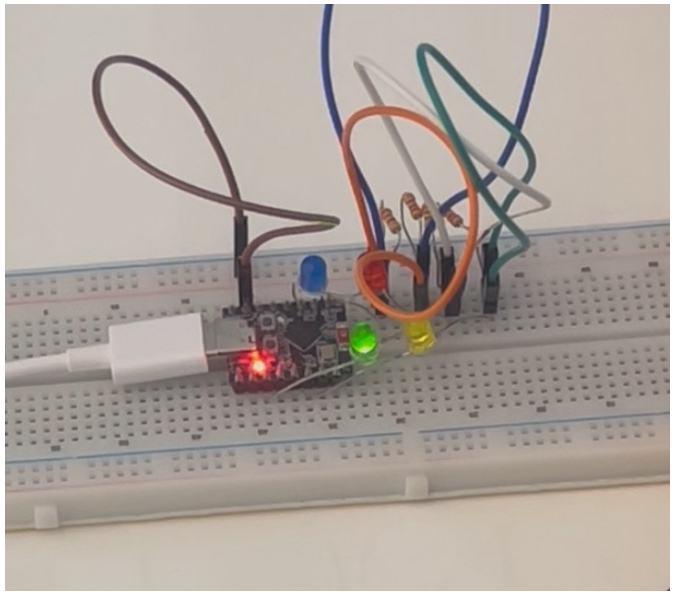


/unlock

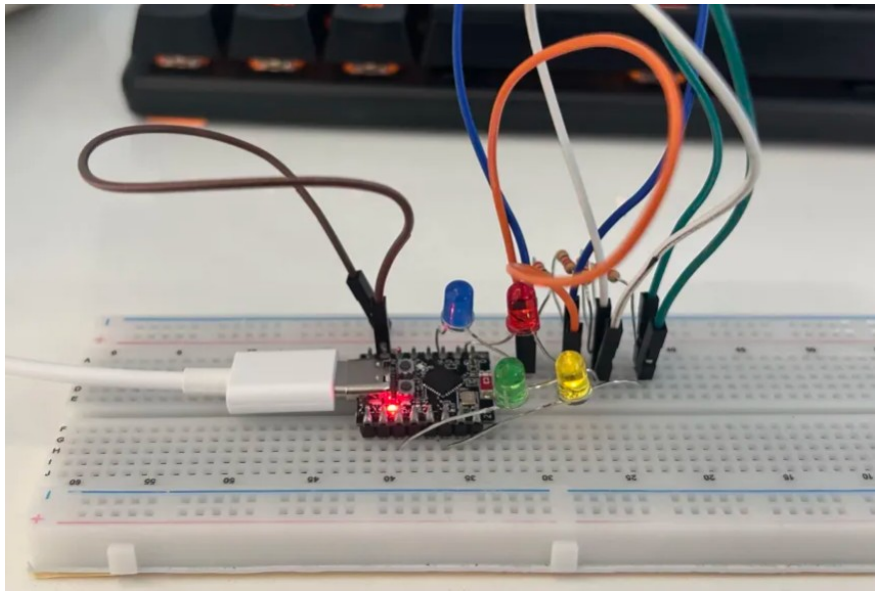
수동 승인 후 초록 복귀

매번 새 공격자 IP 를 사용한다 — 이전 시연 IP 는 10 분 윈도우에 남아 있어 재탐지되기 때문

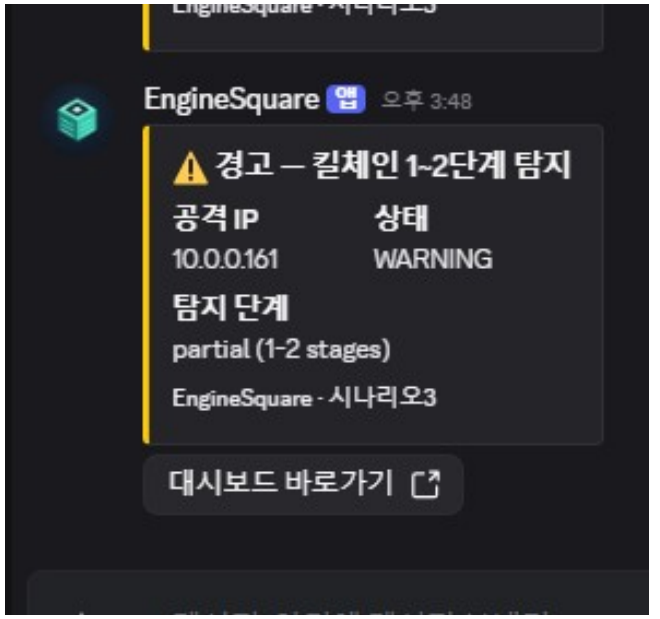
시연 ① 2 단계만 : 노랑에서 멈춘다 (오탐 방지)



[사진] 시연 전 상태
ESP32 초록



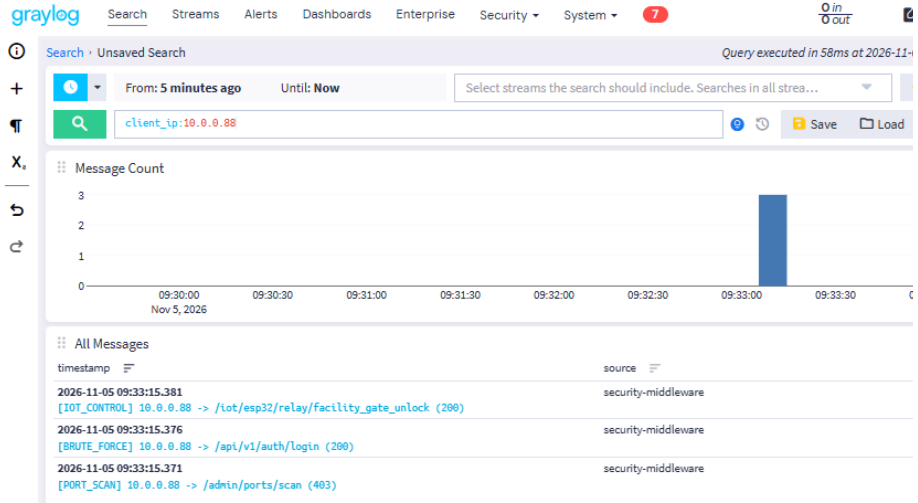
ESP32 노랑 점등
WARNING



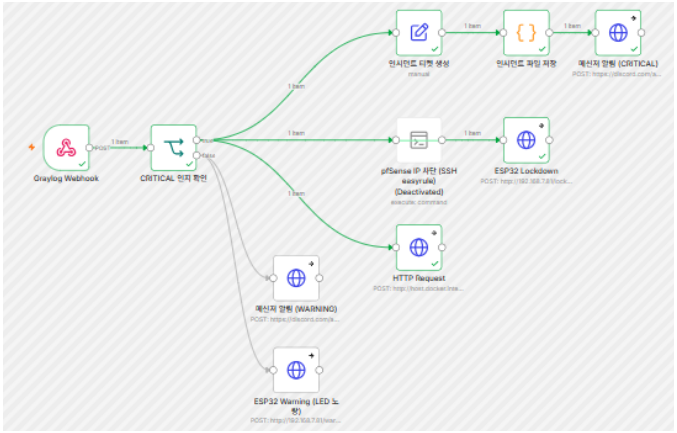
Discord 봇 경고 알림

서로 다른 유형 2 종 → WARNING. 차단하지 않고 지켜본다 .

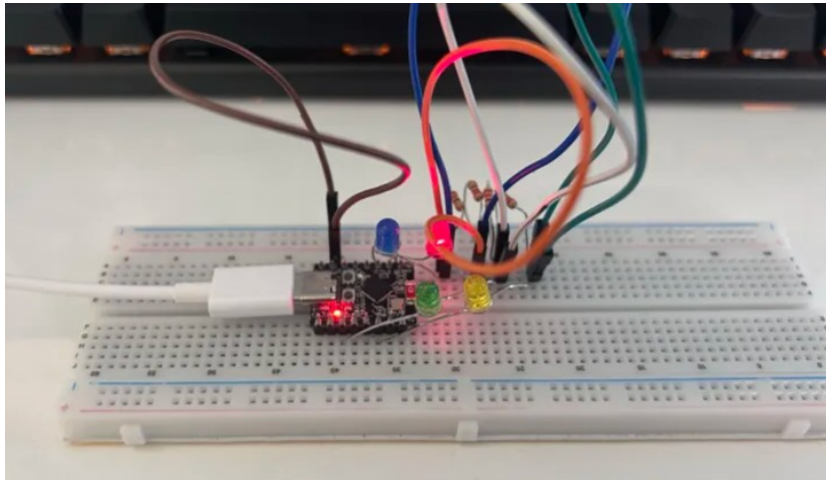
시연 ② 3 단계 모두 : CRITICAL 판정



Graylog 검색
같은 client_ip · 이벤트 3 종



n8n 실행 기록
CRITICAL 분기 노드 전부 초록

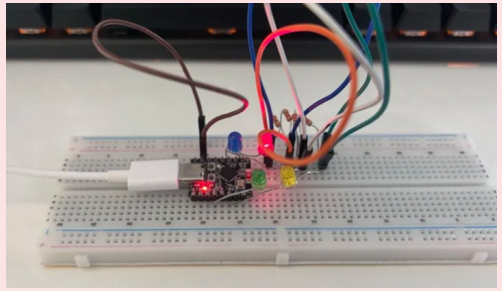


ESP32 빨강 고정
CRITICAL

PORT_SCAN → BRUTE_FORCE → device_control, 10 분 안에 3 종

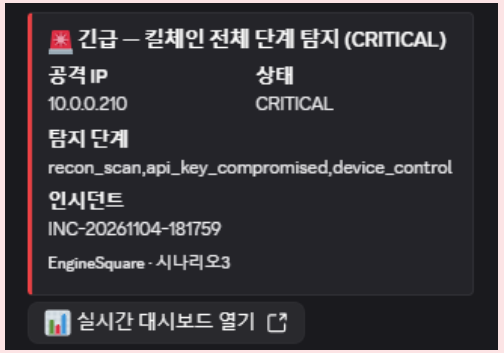
시연 ③ CRITICAL 이면 네 가지가 동시에 일어난다

ESP32



3 회 깜빡임 후 빨강 고정

Discord 봇



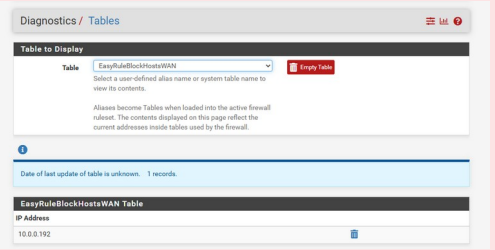
공격 IP · 인시던트 번호

대시보드



INC-KILLCHAIN 티켓

pfSense



공격 IP 차단 규칙

Lockdown 중 장치 제어 요청은 423 거부 . 해제는 조장 승인 후 /unlock 으로만 → 초록 복귀

약한 신호 하나하나는 애매하지만, 이어지면 공격이다

정찰
포트 스캔

→

침투
유출 키 재사용

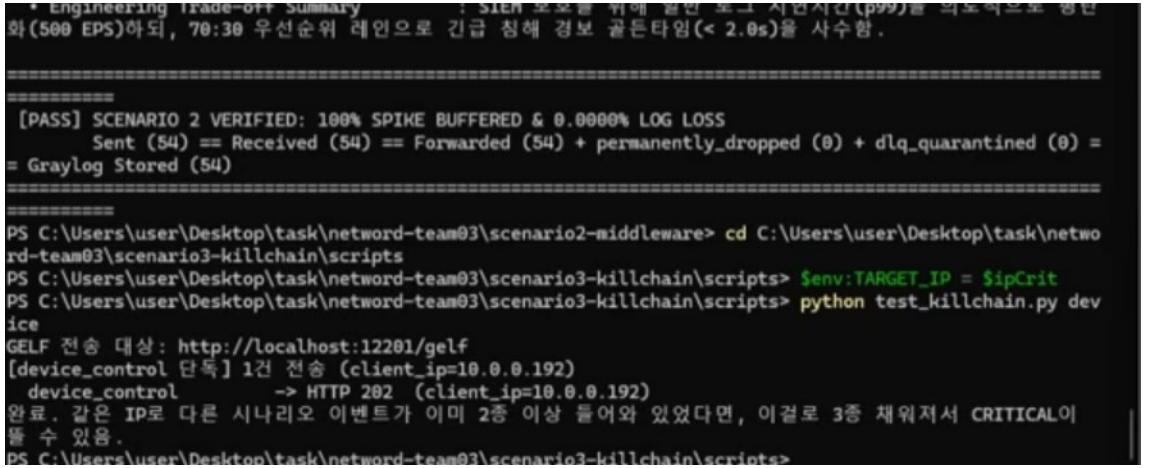
→

장치 제어
IoT 호출

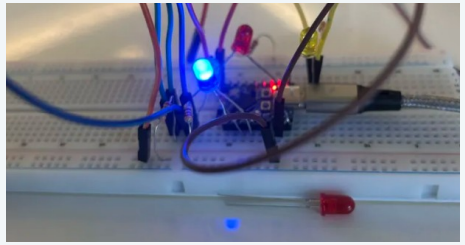
같은 IP
10 분
3 종 이상

그래서 시나리오 3

- 시나리오 1·2 가 개별 이벤트를 잡고, 시나리오 3 이 그 연결을 본다
- 단독으로는 전조 신호인 이벤트도 연속되면 CRITICAL 로 판정



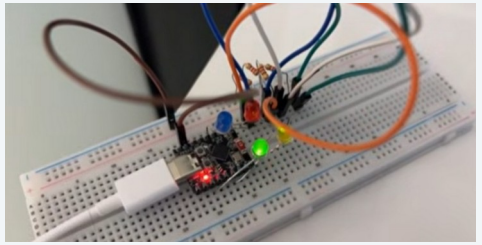
네 가지 상태로 알림 피로를 줄였다



부팅

boot

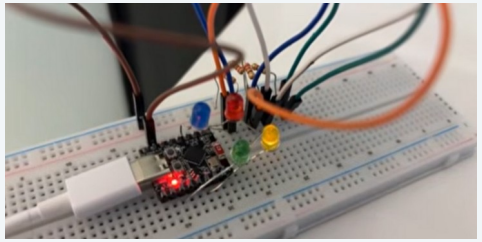
장비 시작



정상

normal

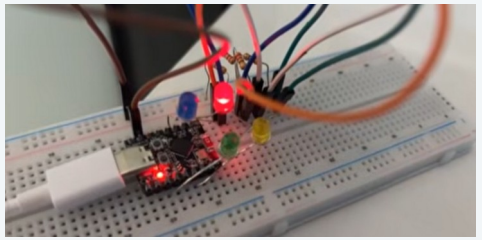
이상 없음



경고

WARNING

1~2 단계 · 차단 없이 관찰



위급

CRITICAL

3 단계 확정 · 차단 + Lockdown

경고와 CRITICAL 을 나눈 이유 : 정찰만으로 울리면 정말 중요한 순간이 묻힌다

Graylog 는 한 번만 부르고 , 대응은 n8n 이 퍼뜨린다

API 서버 · IoT 로그 → Middleware → Graylog 규칙 → n8n 웹훅

▼ 병렬 호출

pfSense 차단 | ESP32 Lockdown | 대시보드 티켓 | Discord 봇 알림

느슨한 결합

- Graylog 는 장비를 직접 건드리지 않는다 → 대응 추가는 n8n 노드 하나만 늘리면 된다

규칙 : client_ip 로 묶고 , 10 분 안에 3 종이면 발동

```
event_type:(
  recon_scan OR PORT_SCAN OR
  api_key_compromised OR
  BRUTE_FORCE OR device_control
)
group by client_ip · 10 분 · 서로 다른 유형 ≥ 3
```

3 종 이상

→ CRITICAL (차단 + Lockdown)

2 종

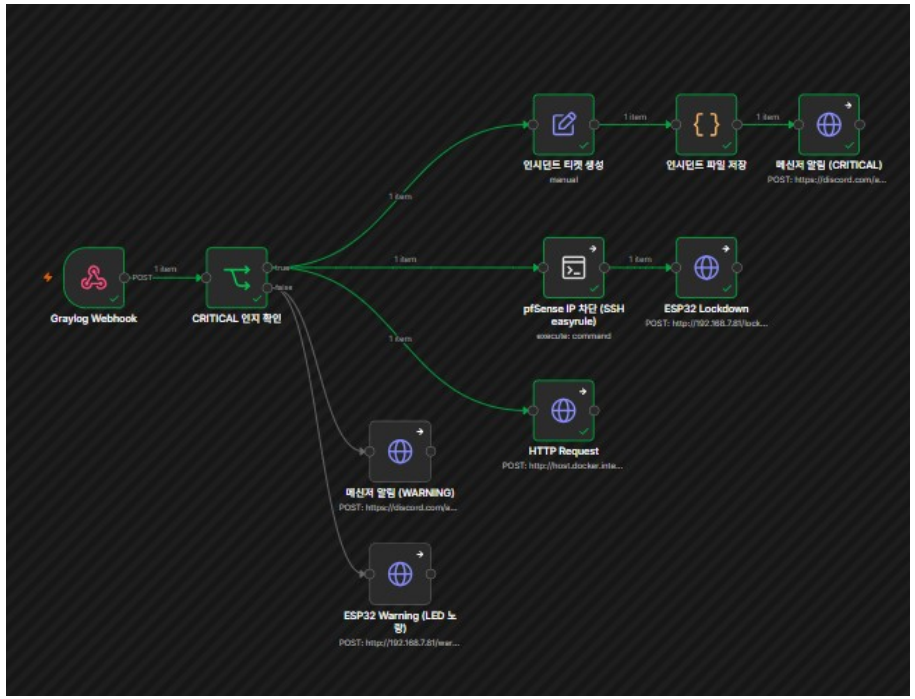
→ WARNING (노랑에서 멈춤)

팀 전체 로그 연동 : 시나리오 1 의 PORT_SCAN · BRUTE_FORCE 도 같은 client_ip 필드 → 실공격 로그가 입력으로 들어온다

All Messages

timestamp	source
2026-11-05 09:33:15.381 [IOT_CONTROL] 10.0.0.88 -> /iot/esp32/relay/facility_gate_unlock (200)	security-middleware
2026-11-05 09:33:15.376 [BRUTE_FORCE] 10.0.0.88 -> /api/v1/auth/login (200)	security-middleware
2026-11-05 09:33:15.371 [PORT_SCAN] 10.0.0.88 -> /admin/ports/scan (403)	security-middleware

n8n: CRITICAL 이면 세 갈래 , 아니면 경고만



CRITICAL → 병렬 4 개

pfSense 차단	ESP32 Lockdown
대시보드 티켓	Discord 봇 CRITICAL

그 외 → 경고만

ESP32 Warning	Discord 봇 WARNING

처음으로 끝까지 연결

- ESP32 노드를 플레이스홀더에서 실제 보드 IP· 토큰으로 교체 → 탐지부터 물리 반응까지 완주

ESP32-C3: 독립형 HTTP 서버로 상태를 눈에 보이게

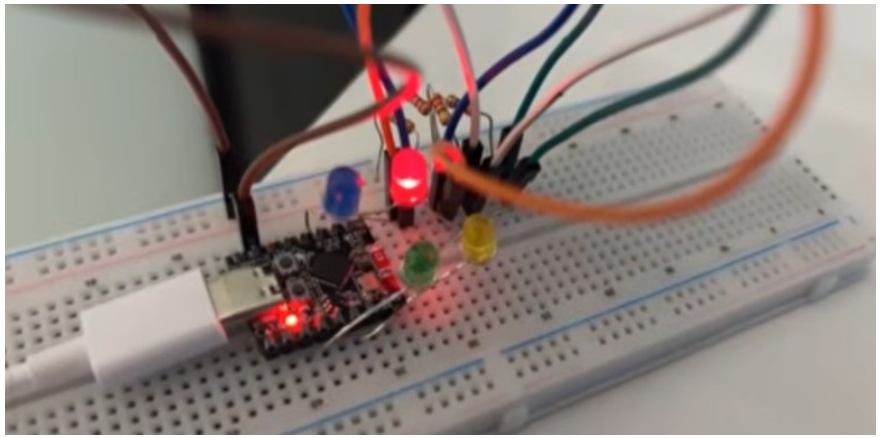
엔드포인트	동작	인증
/status	현재 상태 조회	-
/warning	노랑 경고	토큰 헤더
/lockdown	3 회 깜빡임 후 빨강 고정	토큰 헤더
/unlock	해제 → 초록 복귀	토큰 헤더
/device	장치 제어 (Lockdown 중 423)	-

Lockdown 중 경고는 무시하고 장치 제어는 423 으로 거부한다 .

스트래핑 핀 GPIO8·9 는 부팅 모드를 정하므로 처음부터 피했고 ,
배포 전 PowerShell 로 엔드포인트를 하나씩 호출해 상태 전이를 확인했다 .

최종 핀 배치

- 파랑 GPIO2 · 초록 GPIO7
- 노랑 GPIO10 · 빨강 GPIO0



가장 오래 걸린 문제 : 파랑만 켜지고 나머지가 안 켜졌다

배제한 가설

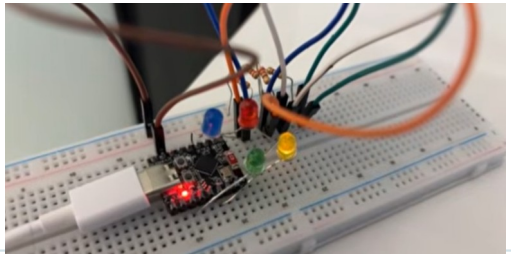
- ✕ 부품 · 저항 교체
- ✕ 브레드보드 없이 3V3 직결
- ✕ 펌웨어 삭제 후 재업로드
- ✕ REPL 에서 핀에 값 직접 출력

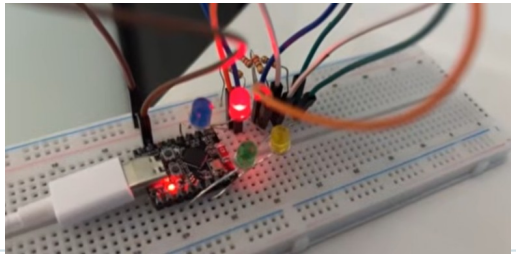
결정적 단서

REPL 에서 핀에 값을 직접 줘도 코드는 정상 , LED 만 꺼짐 .
→ 핀이 꽂힌 브레드보드 칼럼 접촉 불량

해결

GPIO3·5·6 을 버리고 GPIO0·7·10 으로 새 칼럼에 재배선





n8n → pfSense SSH 가 handshake 타임아웃으로 실패

증상

연결 테스트는 통과
실행만 handshake 타임아웃

격리

같은 컨테이너의 시스템 ssh 는 바로 성공

원인

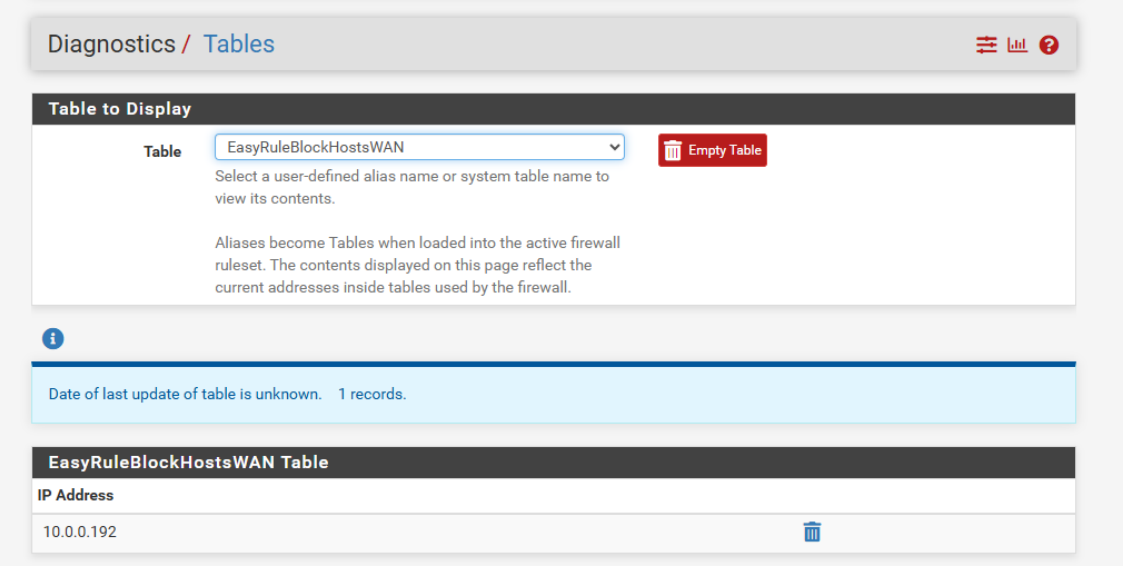
n8n 내장 ssh2 라이브러리의 알고리즘 협상 실패

해결

Password → Ed25519 개인키 인증으로 교체

부수 효과

- 이 문제로 CRITICAL 분기의 나머지 노드까지 막혀 있었고 , 함께 풀렸다 .



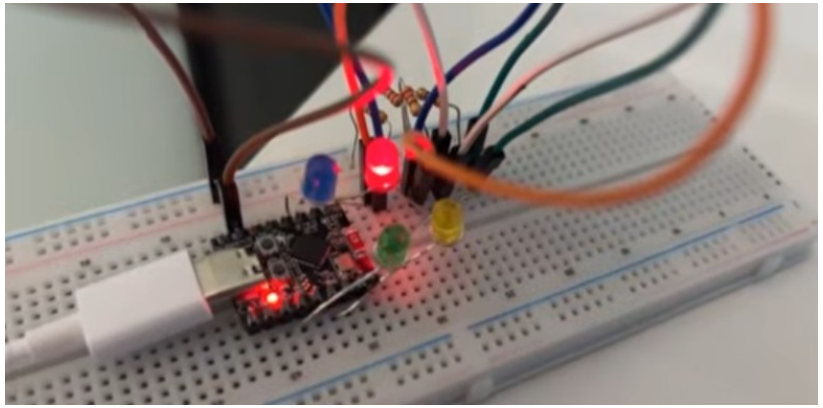
교훈 : 같은 증상도 층이 다르면 해결이 다르다

문제	해결
Wi-Fi 드라이버 상태 오류	재초기화 후 재접속
Lockdown 중 경고가 안 먹힘	설계 의도로 확인 (되돌림 방지)
Graylog 알림 IP· 단계 필드 공란 + 배경 부하테스트 트래픽 오탐 WARNING 대량 발생	Notification 템플릿을 group_by_fields 로 수정 + 쿼리에 노이즈 IP 대역 제외 필터 추가

얻은 교훈

원인이 어느 층인지 모르면 증상만 쫓게 된다 .

하나씩 배제해 범위를 좁히는 isolation 이 가장 빨랐다 .



한계와 개선 : 순서 판정 , 상태 영속 , 통합 리허설

현재 한계

- 3 종 모였는지만 보고 순서는 안 봄
- Lockdown 상태는 보드 메모리뿐 (재부팅 시 초기화)
- n8n 에 보드 IP 가 직접 들어 있음

개선 계획

- 순서까지 판정하는 규칙
- pfSense 이중화 · 다중 장비 확장



세 시나리오 , 하나의 관제 흐름

1

2 만 건 무손실

로그 버퍼링 · 직접 전송은 37.6% 유실

2

키 교체 + IP 차단

유출 키 탐지 후 자동 대응

3

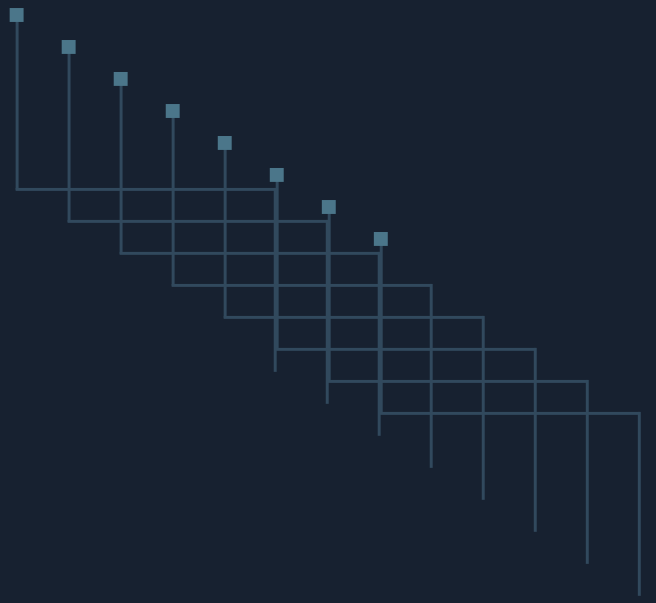
탐지 → 차단 → LED

킬체인 확정 시 사람 손 없이 대응

	향후 계획
단기	동일 IP 로 시나리오 1·2·3 실공격 전 구간 재현 · incident_id 포맷 재확인 · pfSense 키 인증 재확인
중기	Kafka/Redpanda 전환 · 허용 IP 내 키 악용 탐지
장기	탐지 시나리오 확장 · pfSense 이중화 · ESP32 다중 장비

Q&A

질문 받겠습니다

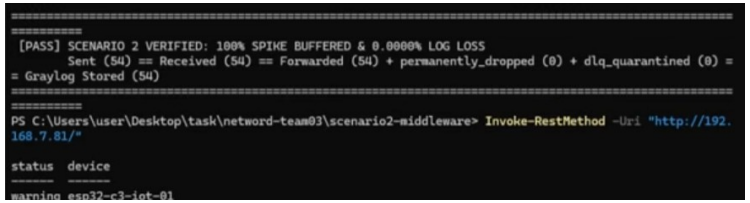


ALEPH 3 조 · 강아름 · 김라연 · 유지원

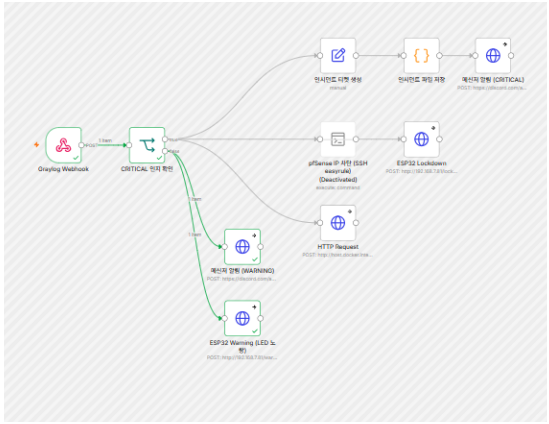
부록 : 시연 증적 모음



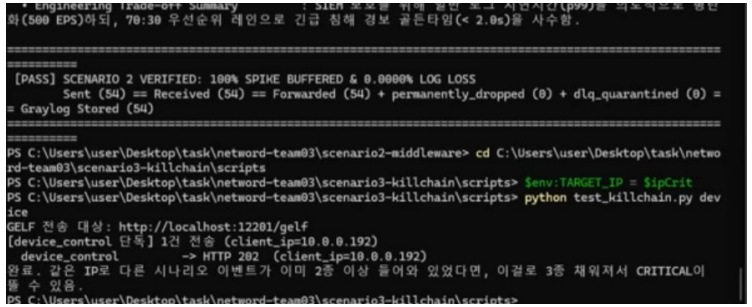
시연 전 : 보드 status normal



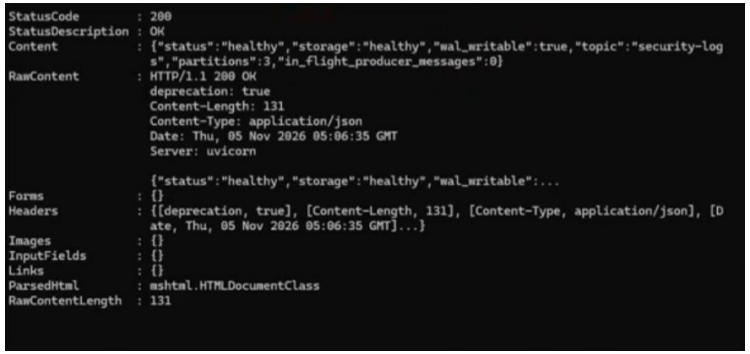
2 단계 후 : 보드 status warning



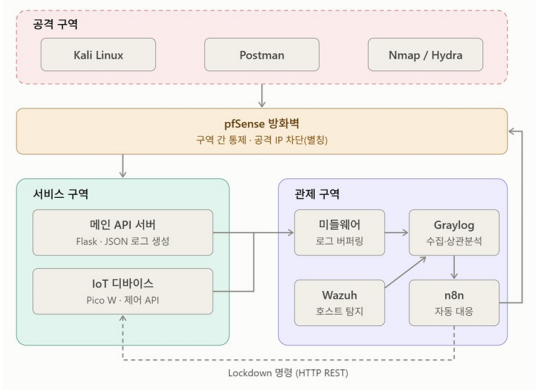
n8n 실행 : WARNING 분기



device_control 전송 (HTTP 202)



Middleware health: healthy



전체 구성도